

OWASP (Open Web Application Security Project)

Audit Internal Sistem Informasi Berbasis OWASP

OWASP Application Security Standard

Isilah identitas audit di bawah ini dengan jelas. Bukti audit dapat berupa screenshot respon sistem.

Nama Sistem	
Unit Pengelola	
Teknologi	Programming Language : Back-end Framework : Front-end Framework : Database : Web Server : OS : Arsitektur Design : ☐ MVC ☐ MVVM ☐ Microservices ☐ Monolithic ☐ Serverless
URL Sistem	
Auditor	
Tanggal Audit	
Firewall Server	☐ Block Port 22 (SSH) ☐ Allow Port 80 (HTTP) ☐ Allow Port 443 (HTTPS) ☐ Block Port 3306 (Database) ☐ Block Port 25/587/465 (SMTP)
Link Bukti Audit	

A. Authentication & Session Management (10%)

(OWASP A07 – Identification and Authentication Failures)

No	Item Pemeriksaan	Yes	No	Catatan
A1	(2%) Sistem tidak menggunakan session ID di URL	☐	☐	
A2	(1%) Session disimpan hanya melalui cookie	☐	☐	
A3	(1%) Cookie session menggunakan HttpOnly	☐	☐	
A4	(1%) Cookie session menggunakan Secure (HTTPS)	☐	☐	
A5	(1%) Cookie session menggunakan SameSite	☐	☐	
A6	(1%) Session ID diregenerasi setelah login	☐	☐	
A7	(1%) Session timeout diterapkan (≤ 30 menit)	☐	☐	
A8	(1%) Session otomatis logout saat <i>idle</i> (<i>tidak ada aktivitas dalam suatu periode waktu tertentu</i>)	☐	☐	
A9	(1%) Session di <i>destroy</i> (dihancurkan) saat logout	☐	☐	

B. Authorization & Access Control (10%)

(OWASP A01 – Broken Access Control)

No	Item Pemeriksaan	Yes	No	Catatan
B1	(2%) Memetakan URL routing engine	☐	☐	
B2	(2%) Access modifier (public, private, protected, default)	☐	☐	
B3	(2%) Setiap <i>endpoint</i> dicek hak aksesnya	☐	☐	
B4	(1%) URL sensitif tidak bisa diakses langsung	☐	☐	
B5	(1%) Validasi akses dilakukan di server	☐	☐	
B6	(1%) Role pengguna didefinisikan jelas (Admin/Dosen/Mhs)	☐	☐	
B7	(1%) User tidak bisa akses data user lain	☐	☐	

C. Input Validation & Injection Protection (10%)

(OWASP A03 – Injection)

No	Item Pemeriksaan	Yes	No	Catatan
C1	(2%) Semua input divalidasi server-side	☐	☐	
C2	(2%) Query database menggunakan prepared statement	☐	☐	
C3	(2%) Tidak ada query SQL manual dari input user	☐	☐	
C4	(2%) File upload divalidasi tipe & ukuran	☐	☐	
C5	(2%) Nama file di-sanitize (dibersihkan/diganti)	☐	☐	

D. Cross-Site Scripting (XSS) Protection (10%)

(OWASP A03 – Injection)

No	Item Pemeriksaan	Yes	No	Catatan
D1	(2%) Output HTML di-escape (htmlspecialchars)	☐	☐	
D2	(2%) Cookie sensitif HttpOnly	☐	☐	
D3	(2%) Tidak ada script inline dari input user (data tidak pernah dieksekusi sebagai kode javascript)	☐	☐	
D4	(2%) Content Security Policy diterapkan (security header)	☐	☐	
D5	(2%) Skor max (mobile 90, desktop 95) di situs Google PageSpeed Insights https://pagespeed.web.dev/	☐	☐	

E. Cross-Site Request Forgery (CSRF) (10%)

(OWASP A01 – Broken Access Control)

No	Item Pemeriksaan	Yes	No	Catatan
E1	(4%) Semua form penting menggunakan CSRF Token	☐	☐	
E2	(2%) Token diverifikasi server-side	☐	☐	
E3	(2%) Token unik per session	☐	☐	
E4	(2%) Method POST digunakan untuk aksi penting	☐	☐	

F. Data Protection & Cryptography (10%)

(OWASP A02 – Cryptographic Failures)

No	Item Pemeriksaan	Yes	No	Catatan
F1	(2%) Password disimpan dengan hashing (bcrypt/argon2)	☐	☐	
F2	(2%) Tidak ada password plain text	☐	☐	
F3	(2%) HTTPS diterapkan di seluruh sistem	☐	☐	
F4	(2%) Data sensitif tidak tampil di URL (GET method)	☐	☐	
F5	(2%) Permintaan HTTP via IP dialihkan ke HTTPS domain	☐	☐	

G. Logging & Monitoring (10%)

(OWASP A09 – Security Logging and Monitoring Failures)

No	Item Pemeriksaan	Yes	No	Catatan
G1	(2%) Login dan logout dicatat	☐	☐	
G2	(2%) Percobaan login gagal dicatat	☐	☐	
G3	(1%) Aktivitas admin dicatat	☐	☐	
G4	(1%) Log disimpan aman dan tidak public	☐	☐	
G5	(2%) Monitoring log secara otomatis menggunakan Script	☐	☐	
G6	(2%) Monitoring log secara otomatis menggunakan AI	☐	☐	

H. Konfigurasi & Deployment (10%)

(OWASP A05 – Security Misconfiguration)

No	Item Pemeriksaan	Yes	No	Catatan
H1	(2%) Error detail tidak ditampilkan ke end-user	☐	☐	
H2	(2%) Mode debug dimatikan di production	☐	☐	
H3	(2%) File konfigurasi tidak bisa diakses publik	☐	☐	
H4	(2%) Permission folder sudah minimum	☐	☐	
H5	(1%) Directory list tidak ditampilkan di browser	☐	☐	
H6	(1%) Nonaktifkan fungsi berbahaya eksekusi command dari webshell seperti exec(), system(), shell_exec(), dll.	☐	☐	

I. Security (10%)

(OWASP A05 – Security Misconfiguration)

No	Item Pemeriksaan	Yes	No	Catatan
I1	(1%) Handle HTTP code 403 (<i>forbidden</i>) dan 404 (<i>not found</i>)	☐	☐	
I2	(1%) Port 22 (SSH) di ganti	☐	☐	
I3	(1%) Firewall standard (iptables / UFW) diaktifkan	☐	☐	
I4	(1%) Root database diganti/non aktifkan.	☐	☐	
I5	(1%) User database permission (<i>select, delete, update, insert</i>)	☐	☐	
I6	(1%) Satpam otomatis server (<i>Fail2Ban</i>) untuk SSH, Mail server, Web login (Nginx / Apache), FTP atau dll.	☐	☐	
I7	(2%) HTTP Security Header yang lengkap dan memperoleh nilai A+ pada situs pengujian <i>securityheaders.com</i>	☐	☐	
I8	(2%) Akses menggunakan SSH key-based authentication (<i>public dan private key</i>)	☐	☐	

J. Backup & Recovery (10%)

No	Item Pemeriksaan	Yes	No	Catatan
J1	(6%) Backup data rutin dilakukan	☐	☐	
J2	(2%) Backup diuji pemulihannya	☐	☐	
J3	(2%) Backup disimpan terpisah	☐	☐	

Kesimpulan Audit:

- ✓ Tingkat Risiko : Rendah / Sedang / Tinggi
- ✓ Rekomendasi Umum :
- ✓ Tindak Lanjut :

Total Score

Pernyataan Kepatuhan:

Sistem (telah / belum) memenuhi prinsip keamanan aplikasi web berbasis **OWASP Top 10** dan memerlukan perbaikan pada aspek tertentu sebagaimana dicatat dalam laporan audit ini.

Auditor,

(.....)